

Compromised and malicious applications investigation

garrodonnell

21–27 minutes

This article provides guidance on identifying and investigating malicious attacks on one or more applications in a customer tenant. The step-by-step instructions help you take the required remedial action to protect information and minimize further risks.

- **Prerequisites:** Covers the specific requirements you need to complete before starting the investigation. For example, logging that should be turned on, roles and permissions required, among others.
- **Workflow:** Shows the logical flow that you should follow to perform this investigation.
- **Investigation steps:** Includes a detailed step-by-step guidance for this specific investigation.
- **Containment steps:** Contains steps on how to disable the compromised applications.
- **Recovery steps:** Contains high-level steps on how to recover/mitigate from a malicious attack on compromised applications.
- **References:** Contains other reading and reference materials.

Before starting the investigation, make sure you have the correct tools and permissions to gather detailed information.

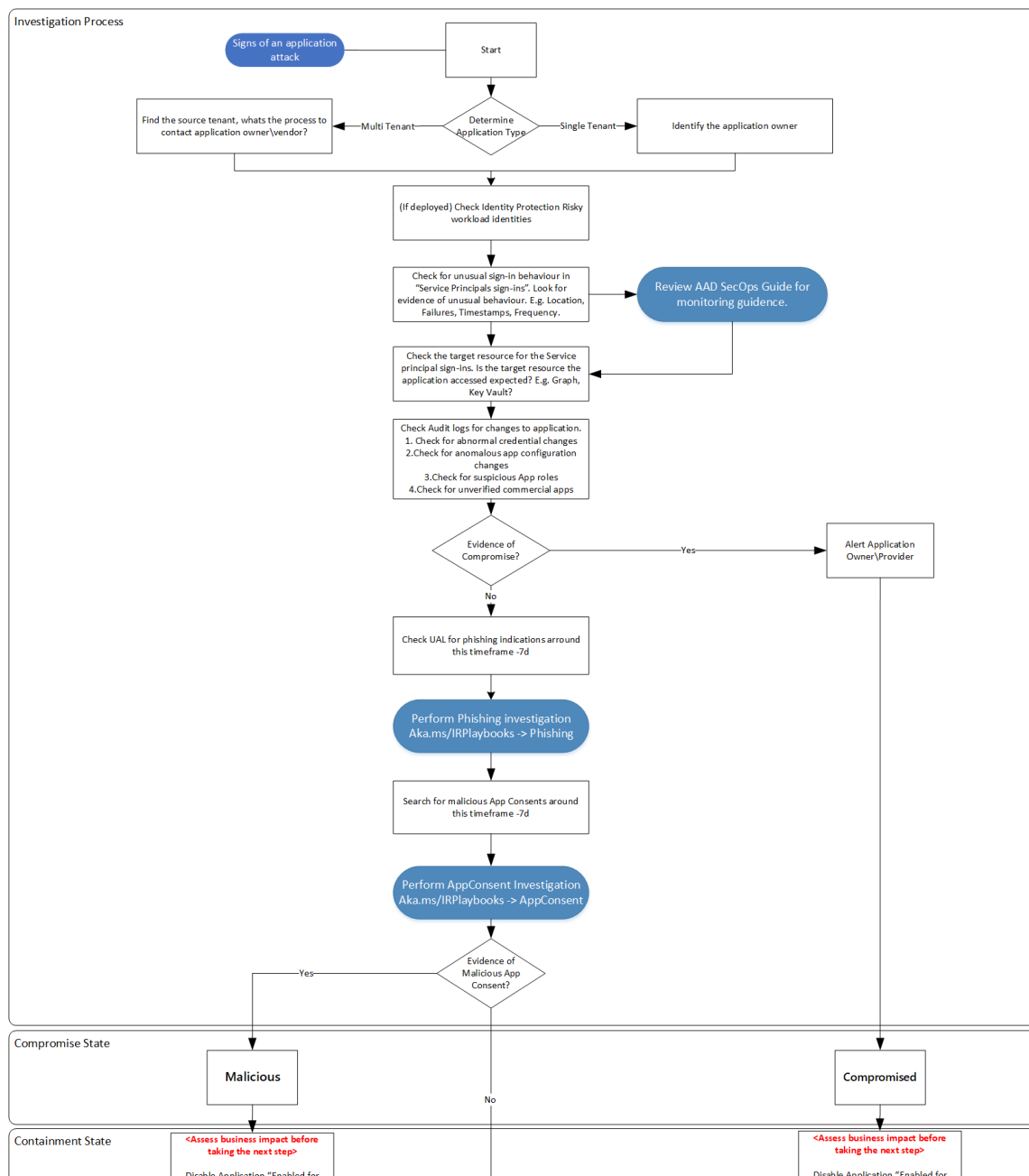
- To use Identity protection signals, the tenant must be licensed for Microsoft Entra ID P2.
- Understanding of the [Identity Protection risk concepts](#)
- Understanding of the [Identity Protection investigation concepts](#)
- An account with at least the [Security Administrator](#) role.
- Ability to use [Microsoft Graph Explorer](#) and be familiar (to some extent) with the Microsoft Graph API.
- Familiarize yourself with the [application auditing concepts](#) (part of <https://aka.ms/AzureADSecOps>).
- Make sure all Enterprise apps in your tenant have an owner set for the purposes of accountability. Review the concepts on [overview of app owners](#) and [assigning app owners](#).
- Familiarize yourself with the concepts of the [App Consent grant investigation](#) (part of <https://aka.ms/IRPlaybooks>).
- Make sure you understand the following Microsoft Entra permissions:
 - [Risky permissions](#)
 - [Consent model and the Admin consent workflow](#)
- Familiarize yourself with the concepts of [Workload identity risk detections](#).
- You must have full Microsoft 365 E5 license to use Microsoft Defender for Cloud Apps.
- Understand the concepts of [anomaly detection alert investigation](#)
- Familiarize yourself with the following application management policies:
 - [Microsoft Entra application authentication methods API overview](#)

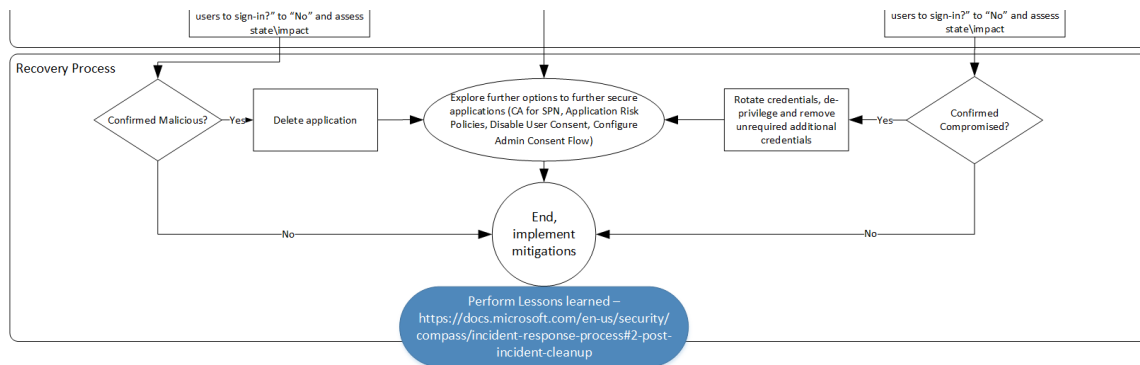
([preview](#))

- [appManagementPolicy resource type](#)
- Familiarize yourself with the following app governance policies:
- [The App Governance blog](#)
- [App governance in Defender for Cloud Apps](#)

For an effective investigation, install the following PowerShell module and the toolkit on your investigation machine:

- [Microsoft Entra Incident Response PowerShell Module](#)
- [Microsoft Entra Toolkit](#)





For this investigation, assume that you either have an indication for a potential application compromise in the form of a user report, Microsoft Entra sign-in logs example, or an identity protection detection. Make sure to complete and enable all required prerequisite steps.

This playbook is created with the intention that not all Microsoft customers and their investigation teams have the full Microsoft 365 E5 or Microsoft Entra ID P2 license suite available or configured. This playbook highlights other automation capabilities when appropriate.

It's important to determine the type of application (multi or single tenant) early in the investigation phase to get the correct information needed to reach out to the application owner. For more information, see [Tenancy in Microsoft Entra ID](https://docs.microsoft.com/en-us/entra/identity/access/application-tenancy).

For multitenant applications, the application is hosted and managed by a third party. Identify the process needed to reach out and report issues to the application owner.

Find the contact details of the application owner within your organization. You can find it under the **Owners** tab on the **Enterprise Applications** section. Alternatively, your organization might have a database that has this information.

You can also execute this Microsoft Graph query:

```
GET https://graph.microsoft.com/v1.0/
applications/{id}/owners
```

This feature is in preview at the time of writing this playbook and licensing requirements apply to its usage. Risky workload identities can be the trigger to investigate a Service Principal, but can also be used to further investigate into other triggers you've identified. You can check the **Risk State** of a Service Principal using the **Identity Protection - risky workload identities** tab, or you can use Microsoft Graph API. You can also use natural language prompts to get insights on risky workload identities with [Microsoft Security Copilot in Microsoft Entra](#).

rove > Security

Security | Risk detections

Search (Ctrl+ /)

Getting started

Protect

Conditional Access

Identity Protection

Security Center

Continuous access evaluation

Verifiable credentials (Preview)

Manage

Identity Secure Score

Named locations

Authentication methods

MFA

Report

Learn more

Download

Refresh

Something went wrong. Please retry.

Auto refresh : Every 5 minutes

Detection type : Leaked credential

User detections

Workload identity

Detection time	Activity time
3/30/2022, 3:11:19 PM	3/30/2022, 3:11:19 PM
3/30/2022, 11:05:00 AM	3/30/2022, 11:05:00 AM
3/16/2022, 7:16:54 PM	3/16/2022, 7:16:54 PM
3/16/2022, 7:15:28 PM	3/16/2022, 7:15:28 PM
3/16/2022, 7:11:21 PM	3/16/2022, 7:11:21 PM

Risk Detection Details

Service principal's risk report

Service principal's sign-ins

Detection type

Suspicious sign-ins

Learn how to investigate

Risk state

At risk

Risk level

High

Risk detail

-

Source

Unknown

Detection timing

Offline

Activity

Service Principal

Detection time

1/11/2022, 6:59 PM

Detection last updated

1/11/2022, 6:59 PM

Application ID

00001111-aaaa-2222-bbbb-3333cccc4444

Key ID

aaaaaaaa-0b0b-1c1c-2d2d-333333333333

Service principal name

Contoso Sales Tracker

Service principal ID

aaaaaaaa-bbbb-cccc-1111-222222222222

Risk Detection Details



Service principal's risk report Service principal's sign-ins ...

Detection type	Leaked credentials ⓘ Learn how to investigate ↗
Risk state	At risk
Risk level	High
Risk detail	-
Source	Identity Protection
Detection timing	Offline
Activity	Service Principal
Detection time	3/16/2022, 7:16 PM
Detection last updated	3/16/2022, 7:16 PM
Application ID	00001111-aaaa-2222-bbbb-3333cccc4444
Key ID	aaaaaaaa-0b0b-1c1c-2d2d-333333333333
Service principal name	Contoso HR App
Service principal ID	aaaaaaaa-bbbb-cccc-1111-222222222222
Additional info	Click here for more details ↗

```
"id": "11bb11bbcc22dd33ee4455ff55ff55ff22cc22ccdd33ee44ff5566aa66aa",
"requestId": null,
"correlationId": null,
"riskEventType": "leakedCredentials",
"riskState": "atRisk",
"riskLevel": "high",
"riskDetail": "none",
"source": "IdentityProtection",
"detectionTimingType": "offline",
"activity": "servicePrincipal",
"tokenIssuerType": "AzureAD",
"ipAddress": null,
"activityDateTime": "2022-02-16T02:09:15.7173479Z",
"detectedDateTime": "2022-02-16T02:09:15.7173479Z",
"lastUpdatedDateTime": "2022-02-16T02:09:15Z",
"servicePrincipalId": "aaaaaaaa-bbbb-cccc-1111-222222222222",
"servicePrincipalDisplayName": "Contoso Front Desk",
"appId": "00001111-aaaa-2222-bbbb-3333cccc4444",
"keyIds": [],
"additionalInfo": "[{\\"Key\\":\\"alertUrl\\",\\"Value\\":\\"https://github.com/eitzman/Maximum_effort/blob/6aa33dd33ddee44ff55aa6677bb77bb77bb44e/time_to_make_the_chimichangas.txt#L2\\\"}],",
"location": null
```

The first step of the investigation is to look for evidence of unusual authentications patterns in the usage of the Service Principal. Within the Azure portal, Azure Monitor, Microsoft

Sentinel, or the Security Information and Event Management (SIEM) system of your organization's choice, look for the following in the **Service principal sign-ins** section:

- Location - is the Service Principal authenticating from locations\IP addresses that you wouldn't expect?
- Failures - 's there a large number of authentication failures for the Service Principal?
- Timestamps - are there successful authentications that are occurring at times that you wouldn't expect?
- Frequency - is there an increased frequency of authentications for the Service Principal?
- Leak Credentials - are any application credentials hard coded and published on a public source like GitHub?

If you deployed Microsoft Entra ID Identity Protection - risky workload identities, check the **Suspicious Sign-ins and Leak Credentials detections**. For more information, see [workload identity risk detentions](#).

Within Service principal sign-ins, also check the **Resource** that the Service Principal was accessing during the authentication. It's important to get input from the application owner because they're familiar with which resources the Service Principal should be accessing.

Application	Azure AD Domain Services Sync
Application ID	00001111-aaaa-2222-bbbb-3333cccc4444
Resource	Microsoft Graph
Resource ID	a0a0a0a0-bbbb-cccc-dddd-e1e1e1e1e1e1

Use Audit logs to get information on credential changes on

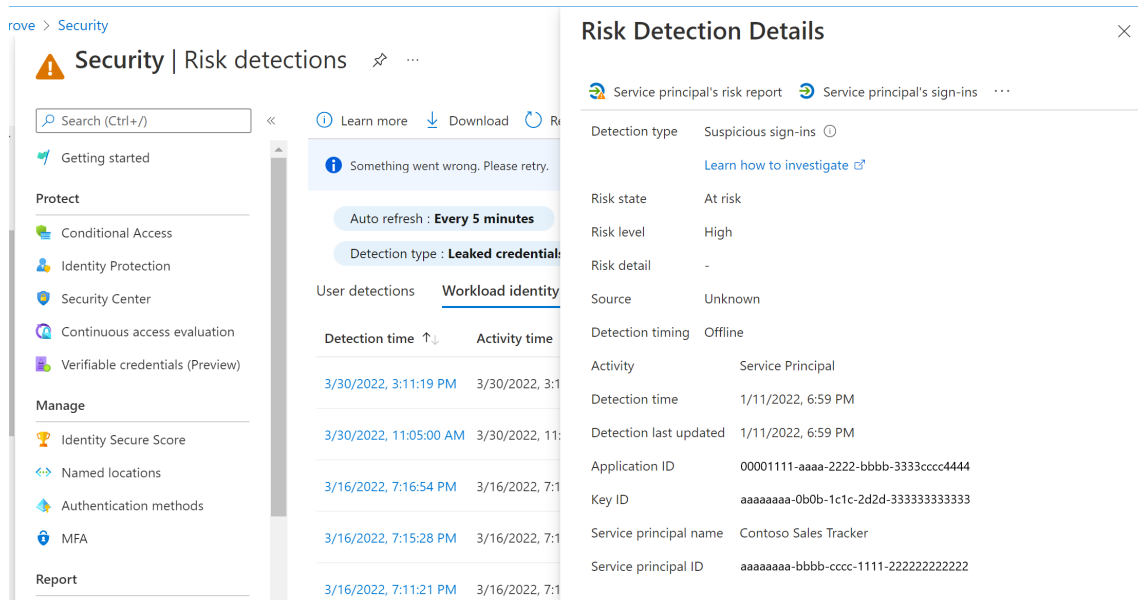
applications and service principals. Filter for **Category** by **Application Management**, and **Activity** by **Update Application – Certificates and secrets management**.

- Check whether there are newly created or unexpected credentials assigned to the service principal.
- Check for credentials on Service Principal using Microsoft Graph API.
- Check both the application and associated service principal objects.
- Check any [custom role](#) that you created or modified. Note the permissions marked below:

☐	microsoft.directory/applications.myOrganization/allProperties/read	Read all properties of single-directory applications.
☐	microsoft.directory/applications.myOrganization/allProperties/update	Update all properties on single-directory applications.
☐	microsoft.directory/applications.myOrganization/audience/update	Update the supported account type on single-directory applications.
☐	microsoft.directory/applications.myOrganization/authentication/update	Update the reply URL, logout URL, implicit flow, and publisher domain on single-directory applications.
☐	microsoft.directory/applications.myOrganization/basic/update	Update basic properties of single-directory applications.
☐	microsoft.directory/applications.myOrganization/credentials/update	Update the certificates and client secrets on single-directory applications.
☐	microsoft.directory/applications.myOrganization/delete	Delete single-directory applications.
☐	microsoft.directory/applications.myOrganization/owners/read	Read owners on single-directory applications.
☐	microsoft.directory/applications.myOrganization/owners/update	Update owner on single-directory applications.
☐	microsoft.directory/applications.myOrganization/permissions/update	Update exposed permissions and required permissions on single-directory applications.
☐	microsoft.directory/applications.myOrganization/standard/read	Read standard properties of single-directory applications.

If you deployed app governance in Microsoft Defender for Cloud Apps, check the Azure portal for alerts relating to the application. For more information, see [Get started with app threat detection and remediation](#).

If you deployed Identity Protection, check the "Risk detections" report and in the user or workload identity "risk history."



If you deployed Microsoft Defender for Cloud Apps, ensure that the "Unusual addition of credentials to an OAuth app" policy is enabled, and check for open alerts.

For more information, see [Unusual addition of credentials to an OAuth app](#).

Additionally, you can query the [servicePrincipalRiskDetections](#) and user [riskDetections APIs](#) to retrieve these risk detections.

- Check the API permissions assigned to the app to ensure that the permissions are consistent with what is expected for the app.
- Check Audit logs (filter **Activity** by **Update Application** or **Update Service Principal**).
- Confirm whether the connection strings are consistent and whether the sign out URL has been modified.
- Confirm whether the domains in the URL are in-line with those registered.
- Determine whether anyone has added an unauthorized redirect URL.
- Confirm ownership of the redirect URI that you own to ensure it

didn't expire and was claimed by an adversary.

Also, if you deployed Microsoft Defender for Cloud Apps, check the Azure portal for alerts relating to the application you are currently investigating. Not all alert policies are enabled by default for OAuth apps, so ensure that these policies are all enabled. For more information, see the [OAuth app policies](#). You can also view information about the apps prevalence and recent activity under the **Investigation > OAuth Apps** tab.

- You can also use the Audit logs. Filter **Activity** by **Add app role assignment to service principal**.
- Confirm whether the assigned roles have high privilege.
- Confirm whether those privileges are necessary.
- Check whether commercial gallery (published and verified versions) applications are being used.

Review your tenant for potential keyCredential property information disclosure as outlined in [CVE-2021-42306](#).

To identify and remediate impacted Microsoft Entra applications associated with impacted Automation Run-As accounts, navigate to the [remediation guidance GitHub Repo](#).

Important

If you discover evidence of compromise, it's important to take the steps highlighted in the containment and recovery sections. These steps help address the risk, but perform further investigation to understand the source of the compromise to avoid further impact and ensure bad actors are removed.

There are two primary methods of gaining access to systems via the use of applications. The first involves an application being consented to by an administrator or user, usually via a phishing

attack. This method is part of initial access to a system and is often referred to as "consent phishing".

The second method involves an already compromised administrator account creating a new app for the purposes of persistence, data collection and to stay under the radar. For example, a compromised administrator could create an OAuth app with a seemingly innocuous name, avoiding detection and allowing long term access to data without the need for an account. This method is often seen in nation state attacks.

Here are some of the steps that can be taken to investigate further.

Sometimes, when attackers use malicious or compromised applications as a means of persistence or to exfiltrate data, a phishing campaign is involved. Based on the findings from the previous steps, you should review the identities of:

- Application Owners
- Consent Admins

Review the identities for indications of phishing attacks in the last 24 hours. Increase this time span if needed to 7, 14, and 30 days if there are no immediate indications. For a detailed phishing investigation playbook, see the [Phishing Investigation Playbook](#).

To get an application added to a tenant, attackers spoof users or admins to consent to applications. To know more about the signs of an attack, see the [Application Consent Grant Investigation Playbook](#).

To see all consent grants for that application, filter **Activity** by **Consent to application**.

- Use the Microsoft Entra admin center Audit Logs

- Use Microsoft Graph to query the Audit logs

a) Filter for a specific time frame:

```
GET https://graph.microsoft.com/v1.0/auditLogs/
auditLogs/directoryAudits?
&$filter=activityDateTime le 2022-01-24
```

b) Filter the Audit Logs for 'Consent to Applications' audit log entries:

```
https://graph.microsoft.com/v1.0/auditLogs/
directoryAudits?directoryAudits?
$filter=ActivityType eq 'Consent to
application'

"@odata.context": "https://graph.microsoft.com/
v1.0/$metadata#auditLogs/directoryAudits",
"value": [
  {
    "id": "Directory_0da73d01-0b6d-4c6c-
a083-afc8c968e655_78XJB_266233526",
    "category": "ApplicationManagement",
    "correlationId": "aaaa0000-
bb11-2222-33cc-444444dddddd",
    "result": "success",
    "resultReason": "",
    "activityDisplayName": "Consent to
application",
    "activityDateTime":
"2022-03-25T21:21:37.9452149Z",
    "loggedByService": "Core Directory",
    "operationType": "Assign",
```

```

    "initiatedBy": {
      "app": null,
      "user": {
        "id": "8b3f927e-4d89-490b-aaa3-e5d4577f1234",
        "displayName": null,
        "userPrincipalName":
"admin@contoso.com",
        "ipAddress": "55.154.250.91",
        "userType": null,
        "homeTenantId": null,
        "homeTenantName": null
      }
    },
    "targetResources": [
      {
        "id":
"d23d38a1-02ae-409d-884c-60b03cadc989",
        "displayName": "Graph explorer
(official site)",
        "type": "ServicePrincipal",
        "userPrincipalName": null,
        "groupType": null,
        "modifiedProperties": [
          {
            "displayName":
"ConsentContext.IsAdminConsent",
            "oldValue": null,
            "newValue": "\"True\""
          }
        ],

```

c) Use Log Analytics

```
AuditLogs
| where ActivityDisplayName == "Consent to
application"
```

For more information, see the [Application Consent Grant Investigation Playbook](#).

A user can authorize an application to access some data at the protected resource, while acting as that user. The permissions that allow this type of access are called "delegated permissions" or [user consent](#).

To find apps that are consented by users, use LogAnalytics to search the Audit logs:

```
AuditLogs
| where ActivityDisplayName == "Consent to
application" and
(parse_json(tostring(parse_json(tostring(TargetResources
[0].newValue))) <> "True")
```

Reviewing the permissions granted to an application or Service Principal can be a time-consuming task. Start with understanding the potentially [risky permissions](#) in Microsoft Entra ID.

Now, follow the guidance on how to enumerate and review permissions in the [App consent grant investigation](#).

Review using Audit Logs:

```
AuditLogs
| where OperationName == "Consent to
application"
//| where
parse_json(tostring(TargetResources[0].modifiedProperties
[4].displayName) == "ConsentAction.Permissions"
```

You can also use the Microsoft Entra audit logs, filter by **Consent to application**. In the Audit Log details section, click **Modified Properties**, and then review the **ConsentAction.Permissions**:

Audit Log Details

Activity	Target(s)	Modified Properties	
Target	Property Name	Old Value	New Value
Graph exp...	ConsentContext...		"True"
Graph exp...	ConsentContext...		"False"
Graph exp...	ConsentContext...		"False"
Graph exp...	ConsentContext...		"WindowsAzureActiveDirectoryIntegratedApp"
Graph exp...	ConsentAction....		"[[Id: oTg90q4CnUCITGCwPK3JiXq_sHy-kV5LnYXsSNlcUgp-kj-LiU0LSaqj5dRXf4lv, ClientId: d23d38a1-02ae-409d-884c-60b03cad989, Principallid: 8b3f927e-4d89-490b-aaa3-e5d4577f896f, ResourceId: 7cb0bf7a-91be-4b5e-9d85-ec48d95c520a, ConsentType: Principal, Scope: UserAuthenticationMethod.Read UserAuthenticationMethod.Read.All UserAuthenticationMethod.ReadWrite UserAuthenticationMethod.ReadWrite.All openid profile Policy.Read.All Policy.Read.ConditionalAccess Policy.Read.PermissionGrant Policy.ReadWrite.ApplicationConfiguration Policy.ReadWrite.AuthenticationFlows Policy.ReadWrite.AuthenticationMethod Policy.ReadWrite.Authorization Policy.ReadWrite.ConditionalAccess Policy.ReadWrite.ConsentRequest Policy.ReadWrite.DeviceConfiguration Policy.ReadWrite.FeatureRollout Policy.ReadWrite.PermissionGrant Policy.ReadWrite.TrustFramework Group.Read.All Group.ReadWrite.All PrivilegedAccess.Read.AzureAD PrivilegedAccess.Read.AzureADGroup PrivilegedAccess.Read.AzureResources PrivilegedAccess.ReadWrite.AzureAD PrivilegedAccess.ReadWrite.AzureADGroup PrivilegedAccess.ReadWrite.AzureResources Directory.AccessAsUser.All Directory.Read.All Directory.ReadWrite.All IdentityProvider.Read.All offline_access Application.Read.All Application.ReadWrite.All, CreatedDateTime: , LastModifiedDateTime]] => [[Id: oTg90q4CnUCITGCwPK3JiXq_sHy-

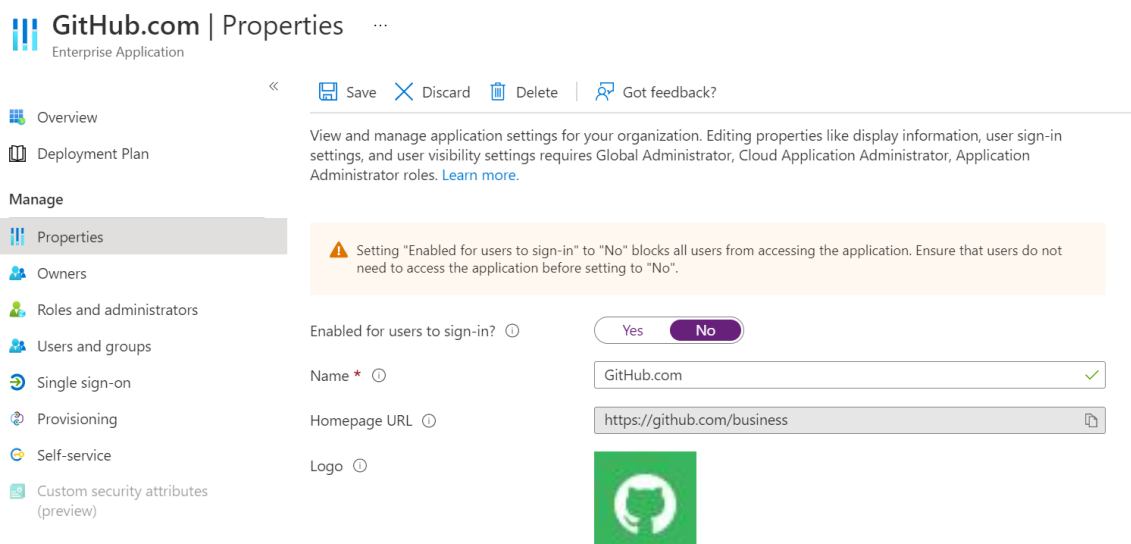
After identifying one or more applications or workload identities as either malicious or compromised, you might not immediately want to roll the credentials for this application, nor you want to immediately delete the application.

Important

Before you perform the following step, your organization must

weigh up the security impact and the business impact of disabling an application. If the business impact of disabling an application is too great, then consider preparing and moving to the Recovery stage of this process.

A typical containment strategy involves the disabling of sign-ins to the application identified, to give your incident response team or the affected business unit time to evaluate the impact of deletion or key rolling. If your investigation leads you to believe that administrator account credentials are also compromised, this type of activity should be coordinated with an eviction event to ensure that all routes to accessing the tenant are cut off simultaneously.



You can also use the following [Microsoft Graph PowerShell](#) code to disable the sign-in to the app:

```
# The AppId of the app to be disabled
$appId = "{AppId}"

# Check if a service principal already exists
for the app
$servicePrincipal = Get-MgServicePrincipal -
Filter "appId eq '$appId'"
```

```

if ($servicePrincipal) {
    # Service principal exists already, disable
    it

    $ServicePrincipalUpdate =@{
        "accountEnabled" = "false"
    }
    Update-MgServicePrincipal -
ServicePrincipalId $servicePrincipal.Id -
BodyParameter $ServicePrincipalUpdate
} else {
    # Service principal does not yet exist,
    create it and disable it at the same time

    $ServicePrincipalID=@{
        "AppId" = $appId
        "accountEnabled" = "false"
    }

    $servicePrincipal = New-MgServicePrincipal -
BodyParameter $ServicePrincipalId
}

```

1. List all credentials assigned to the **Risky Service Principal**.

The best way to do this is to perform a Microsoft Graph call using GET ~/application/{id} where ID passed is the application object ID.

- Parse the output for credentials. The output may contain passwordCredentials or keyCredentials. Record the keyIds for

all.

```
"keyCredentials": [],
  "parentalControlSettings": {
    "countriesBlockedForMinors": [],
    "legalAgeGroupRule": "Allow"
  },
  "passwordCredentials": [
    {
      "customKeyIdentifier": null,
      "displayName": "Test",
      "endDateTime":
"2021-12-16T19:19:36.997Z",
      "hint": "7~-",
      "keyId":
"aaaaaaaa-0b0b-1c1c-2d2d-333333333333",
      "secretText": null,
      "startDateTime":
"2021-06-16T18:19:36.997Z"
    }
  ],
```

2. Add a new (x509) certificate credential to the application object using the application addKey API.

```
POST ~/applications/{id}/addKey
```

3. Immediately remove all old credentials. For each old password credential, remove it by using:

```
POST ~/applications/{id}/removePassword
```

For each old key credential, remove it by using:

```
POST ~/applications/{id}/removeKey
```

4. Remediate all Service Principals associated with the application.

Follow this step if your tenant hosts/registers a multitenant application, and/or registers multiple service principals associated to the application. Perform similar steps to what is previously listed:

- GET ~/servicePrincipals/{id}
- Find passwordCredentials and keyCredentials in the response, record all old keyIds
- Remove all old password and key credentials. Use:

POST ~/servicePrincipals/{id}/removePassword and POST ~/servicePrincipals/{id}/removeKey for this, respectively.

Remediate KeyVault secrets that the Service Principal has access to by rotating them, in the following priority:

- Secrets directly exposed with [GetSecret](#) calls.
- The rest of the secrets in exposed KeyVaults.
- The rest of the secrets across exposed subscriptions.

For more information, see [Interactively removing and rolling over the certificates and secrets of a Service Principal or Application](#).

For Microsoft Entra SecOps guidance on applications, see [Microsoft Entra security operations guide for Applications](#).

In order of priority, this scenario would be:

- Update Graph PowerShell cmdlets (Add/Remove ApplicationKey + ApplicationPassword) doc to include examples for credential roll-over.
- Add custom cmdlets to Microsoft Graph PowerShell that simplifies this scenario.

An application can either be disabled or deleted. To disable the application, under **Enabled for users to sign in**, move the toggle to **No**.

You can delete the application, either temporarily or permanently, in the Azure portal or through the Microsoft Graph API. When you soft delete, the application can be recovered up to 30 days after deletion.

```
DELETE /applications/{id}
```

To permanently delete the application, use this Microsoft Graph API call:

```
DELETE /directory/deletedItems/{id}
```

If you disable or if you soft delete the application, set up monitoring in Microsoft Entra audit logs to learn if the state changes back to enabled or recovered.

Logging for enabled:

- **Service** - Core Directory
- **Activity Type** - Update Service Principal
- **Category** - Application Management
- **Initiated by (actor)** - UPN of actor
- **Targets** - App ID and Display Name
- **Modified Properties** - Property Name = account enabled, new value = true

Logging for recovered:

- **Service** - Core Directory
- **Activity Type** - Add Service Principal
- **Category** - Application Management

- **Initiated by (actor)** - UPN of actor
- **Targets** - App ID and Display Name
- **Modified Properties** - Property name = account enabled, new value = true

Note

Microsoft globally disables applications found to be violating its Terms of Service. In those cases, these applications show `DisabledDueToViolationOfServicesAgreement` on the `disabledByMicrosoftStatus` property on the related [application](#) and [service principal](#) resource types in Microsoft Graph. To prevent them from being instantiated in your organization again in the future, you can't delete these objects.

Microsoft detects risk on workload identities across sign-in behavior and offline indicators of compromise.

For more information, see [Securing workload identities with Identity Protection](#).

These alerts appear in the Identity Protection portal and can be exported into SIEM tools through [Diagnostic Settings](#) or the [Identity Protection APIs](#).

Microsoft Azure Security | Risk detections

Search (Ctrl+/) Learn more Download Refresh Columns Got feedback?

Auto refresh: Off Detection time: Last 90 days Show dates as: Local

Detection type: None Selected Risk state: 2 selected Risk level: None Selected Add filters

User detections **Workload identity detections**

Detection time	Service principal	Detection type	Risk state	Risk level
10/31/2021, 11:40:48 P...	Risky Test App 2	Risk detected	Confirmed compromis...	High
10/27/2021, 12:13:00 ...	Risky Test App 3	Risk detected	Confirmed compromis...	High
10/19/2021, 8:53:56 PM	AADIP-SP-Risk-Test-App	Azure AD threat intelli...	At risk	High
10/19/2021, 8:00:00 PM	Risky Test App 3	Risk detected	At risk	High
10/19/2021, 8:00:00 PM	Risky Test App 2	Risk detected	At risk	High

Conditional Access allows you to block access for specific accounts that you designate when Identity Protection marks them as “at risk.” The enforcement through Conditional Access is currently limited to single-tenant applications only.

New Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name * Risk for Workload Identities ✓

Assignments

Users or workload identities ○

Specific service principals included

Cloud apps or actions ○

All cloud apps

Conditions ○

1 condition selected

Access controls

Grant ○

Block access

Service principal risk (Preview) ○

2 included

Locations ○

Not configured

Some conditions are not available due to 'Workload identities (Preview)' selection in policy assignment

Configure ○

Yes No

Configure service principal risk levels needed for policy to be enforced

☒ High

☒ Medium

☐ Low

For more information, see [Conditional Access for workload identities](#).

Review the user consent settings under **Microsoft Entra ID > Enterprise applications > Consent and permissions > User consent settings**.

User consent for applications

Configure whether users are allowed to consent for applications to access your organization's data.

- ☐ Do not allow user consent
An administrator will be required for all apps.
- ☒ Allow user consent for apps from verified publishers, for selected permissions (Recommended)
All users can consent for permissions classified as "low impact", for apps from verified publishers or apps registered in this organization.
 -  [7 permissions classified as low impact](#)
- ☐ Allow user consent for apps
All users can consent for any app to access the organization's data.

To review configuration options, see [Configure how users consent to apps](#).

When an application developer directs users to the admin consent endpoint with the intent to give consent for the entire tenant, it's known as admin consent flow. To ensure the admin consent flow works properly, application developers must list all permissions in the `RequiredResourceAccess` property in the application manifest.

Most organizations disable the ability for their users to consent to applications. To give users the ability to still request consent for applications and have administrative review capability, it's recommended to implement the admin consent workflow. Follow the [admin consent workflow steps](#) to configure it in your tenant.

For high privileged operations such as admin consent, have a privileged access strategy defined in our [guidance](#).

Risk-based step-up consent helps reduce user exposure to malicious apps. For example, consent requests for newly registered multitenant apps that are not publisher verified and require non-basic permissions are considered risky. If a risky user consent request is detected, the request requires a "step-up" to admin consent instead. This step-up capability is enabled by default, but it results in a behavior change only when user consent is enabled.

Make sure it's enabled in your tenant and review the configuration settings outlined [here](#).

- [Incident Response Playbooks](#)
- [App consent grant](#)
- [Microsoft Entra ID Protection risks](#)
- [Microsoft Entra security monitoring guide](#)
- [Application auditing concepts](#)
- [Configure how users consent to applications](#)
- [Configure the admin consent workflow](#)
- [Unusual addition of credentials to an OAuth app](#)
- [Securing workload identities with Identity Protection](#)
- [Holistic compromised identity signals from Microsoft](#)

Examine guidance for identifying and investigating these additional types of attacks:

- [Phishing](#)
- [Password spray](#)
- [App consent grant](#)
- [Overview](#) for Microsoft security products and resources for new-to-role and experienced analysts
- [Planning](#) for your Security Operations Center (SOC)
- [Microsoft Defender XDR](#) incident response
- [Microsoft Defender for Cloud \(Azure\)](#)
- [Microsoft Sentinel](#) incident response
- [Microsoft Incident Response team guide shares best practices](#)

for security teams and leaders

- Microsoft Incident Response guides help security teams analyze suspicious activity